

INSTITUTO TECNOLÓGICO DE BUENOS AIRES

Trabajo Práctico N° 3

Alumno: Cozzi, Alejandro Luis (Leg. N° 27826374)

Profesor: Salgado, Ariel

TALLER: (20261Q) CD.11 – Comisión: ECD.2025.B

Introducción a la Metodología de Investigación – Maestría en Ciencia de Datos

1. Seleccione al menos 5 referencias bibliográficas, artículos científicos, congresos o revistas que aborden el tema seleccionado y sus alrededores.
2. Describir un breve Estado de la cuestión del problema a ser abordado a partir de las referencias de bibliografía y otras fuentes de información seleccionadas. Indique claramente cuál es el problema a ser abordado. El texto debe desprenderse de la bibliografía explorada y evidenciar cómo el problema se vincula con la literatura (en términos de problemas similares, metodologías empleadas, conceptos relevantes) pero a la vez se distingue de la misma (en términos de las características de la pregunta de investigación, la metodología empleada, los datos empleados u otra opción que corresponda).
3. Definir el problema de investigación a abordar, recontextualizado en el Estado de la cuestión construido en el punto 2.

Estado de la cuestión

Mejorar los niveles de detección de ataques en WAF¹ a partir de los datos, es un problema constante y recurrente dado que la cantidad y creatividad de los ataques se sostiene en el tiempo. Las dinámicas elementales desde el punto de vista técnico para quienes no estén familiarizados con el problema de la seguridad y la acción del WAF son trabajadas en [1] donde se realiza una exploración metodológica acerca de la arquitectura necesaria para detectar y bloquear amenazas de tipo SQLI²; si bien menciona los aportes que podrían hacer las técnicas de *deep learning* en esa capa, no incluye ninguna en su propuesta. Sí aporta algunas nociones metodológicas que podrían ayudar en la etapa de experimentación y, sobre todo, al momento de comparar con los filtros heurísticos.

En cambio [2] realiza una aproximación muy similar a la que pretende plantear este trabajo, aunque sobre presupuestos metodológicos diferentes. Si bien parte de arquitecturas *transformers* para la comprensión semántica de cada solicitud web, apunta al *fine-tuning* a partir de RoBERTa³, antes que a la extracción de *embeddings*

¹Web Application Firewall (WAF) es el software que se utiliza como cortafuegos entre un proveedor de un servicio (ejemplo un sitio web) y un usuario remoto.

²Inyección de SQL (SQLI) es un tipo de ataque informático en el cual se intenta manipular la base de datos que sostiene un servicio web.

³Modelo de tipo Transformers, variante de BERT (Bidirectional Encoder Representations from Transformers)

crudos para su posterior procesamiento. No buscan generalizar sobre un conjunto de solicitudes maliciosas *per se*, sino que proponen realizar un entrenamiento de modelos singulares para cada aplicación web.

Es probable que el entrenamiento singular tenga mucho sentido a la hora de detectar anomalías, aunque no queda del todo claro en ese trabajo cómo se realizaría el etiquetado ya que en los experimentos se utilizan datasets ya etiquetados como CSIC 2010 y DRUPAL.

En una segunda etapa, luego del *fine-tuning* de RoBERTa, utilizan OneClassSVM un clasificador binario para detectar los ataques en los datasets, y lo comparan con los resultados TPR y FPR⁴ usando ModSec⁵ como WAF.

La potencia de RoBERTa también fue utilizada en [3] donde los autores experimentaron con un ensamble bastante más complejo pero con algunos parámetros similares. Su trabajo también utiliza herramientas *transformers*, RoBERTa en particular y el dataset de CSIC 2010 para pruebas, además del dataset ATRDF 2023. Su propuesta se inspira en el framework GAN⁶ de forma muy original: identifican tokens reservados en el dataset original y los enmascaran con un token de máscara (literalmente <MASK>), luego utilizan RoBERTa para generar el reemplazo esperable de esa fracción del código, lo cual entrega un dataset paralelo, distinto del original. A continuación utilizan nuevamente RoBERTa para comparar ambos, y calculan la similitud del coseno de cada palabra para determinar anomalías. Por último, entrenan un clasificador de *Random Forest* para predecir y discriminar entre ‘tráfico normal’ y ‘posible ataque’.

Otra característica en común de los dos trabajos mencionados anteriormente es que ambos obtienen como resultado esa clasificación binaria.

En cambio en [4] los autores apuntan a entregar ambos tipos de clasificación, una binaria (que discrimine ataque / legítimo) y una multiclase, clasificando hasta 8 clases en total (incluyendo al tráfico legítimo). Partiendo de la extracción de *embeddings* de la solicitud http, proceden a añadirle ruido usando el algoritmo DaSana.

Para construir los embeddings utilizaron Keras con un *padding* posterior para normalizar los largos (es decir recortando las líneas que exceden el largo determinado y completando con ceros las que no llegan a él) usando los datasets CSIC-2010 y ECML/PKDD.

Un desarrollo más amplio y complejo se encuentra en [5]. En este trabajo se presenta un proceso que acuña su propio nombre: DeepPTSD una sigla que describe básicamente el proceso propuesto, de *Deep Learning Payload Traffic Detection Method Transfer Semi-Supervised Detection*. Se trata de un ensamble bastante sofisticado que se entrena con datasets clasificados públicos y aspira a detectar líneas maliciosas en un WAF. A grandes rasgos el ensamble sigue un proceso similar a los demás, aunque con variantes en cada paso, por ejemplo los embeddings se extraen con *Word2Vec* luego se pre-entrena un modelo con esa información usando redes convolucionales. Con los resultados se realiza una aumentación de los datos que

⁴Por True Positive Ratio y False Positive Ratio

⁵Mod Security es un WAF de código abierto, desarrollado por OWASP (Open Worldwide Application Security Project)

⁶Red Generativa Adversaria

sigue dos caminos: “keyword mining” que parte de un dataset de payloads⁷ y aplica una ecuación tf-idf para crear una biblioteca de payloads y luego una “payload perturbation” que reemplaza ciertos tokens que detecta similares a los de la biblioteca en la línea a analizar.

Problema

Los trabajos mencionados parecen coincidir en un problema central: las reglas de WAF son eficientes para detectar un alto porcentaje de solicitudes maliciosas, pero son incapaces de detectar algunos tipos de ofuscación. Además, por su propia naturaleza, surgen como reacción a la detección de vulnerabilidades de tipo ‘zero-day’ y esa reacción abre una ventana de oportunidad para el ciberdelito.

Es por eso que se busca en todos una solución al problema a partir de los datos, con distintas estrategias que en definitiva resultan en una acción inmediata sobre una solicitud web, en la capa de WAF. Esta solución no implica un reemplazo del sistema de reglas tradicional, sino un complemento que mejore las métricas de detección. En cualquier caso, eso significa básicamente aumentar el TPR y reducir el FPR con distintas estrategias específicas de la ciencia de datos, en un margen de tiempo poco considerable⁸.

Bibliografía

1. Hassan, A. F. (2026). IMPROVING WEB APPLICATION SECURITY VIA FIREWALL-BASED DETECTION AND PREVENTION OF SQL INJECTION ATTACKS. *Journal of Digital Security and Forensics*, 3(1), 67-74. <https://doi.org/10.29121/digisecforensics.v3.i1.2026.104>
2. Montes, N., Betarte, G., Martínez, R., & Pardo, A. (2021, May). Web application attacks detection using deep learning. In *Iberoamerican Congress on Pattern Recognition* (pp. 227-236). Cham: Springer International Publishing. https://link.springer.com/chapter/10.1007/978-3-030-93420-0_22
3. Aharon, U., Marbel, R., Dubin, R., Dvir, A., & Hajaj, C. (2024). RoBERTa-Augmented Synthesis for Detecting Malicious API Requests. *arXiv preprint arXiv:2405.11258*. <https://arxiv.org/abs/2405.11258>
4. Karacan, H., & Sevri, M. (2021). A novel data augmentation technique and deep learning model for web application security. *IEEE Access*, 9, 150781-150797. https://www.academia.edu/108290354/A_Novel_Data_Augmentation_Technique_and_Deep_Learning_Model_for_Web_Application_Security
5. Chen, T., Chen, Y., Lv, M., He, G., Zhu, T., Wang, T., & Weng, Z. (2021). A Payload Based Malicious HTTP Traffic Detection Method Using Transfer

⁷Payload (carga útil) es el conjunto de parámetros que acompaña una solicitud web como puede ser datos de un formulario, encabezados, tokens de autenticación, etc.

⁸Si bien no hay un tiempo estándar de procesamiento para evaluar una respuesta, lo habitual es que un sitio responda en aproximadamente 2 segundos.

Semi-Supervised Learning. *Applied Sciences*, 11(16), 7188. <https://doi.org/10.3390/app11167188>